

Secure Wireless Networks

WPA3 Configuration and WIPS Implementation — Healthcare IAM Home Lab

Prepared by Sabitha S Karanavar

1. Introduction

This report satisfies the project rubric item “Secure Wireless Networks” for the Healthcare IAM Operations Home Lab. It documents the configuration of WPA3 for one wireless network in the lab and the implementation of a Wireless Intrusion Prevention System (WIPS) to detect and prevent unauthorized wireless access, with one example of a detected event.

Environment note: the lab's virtualized infrastructure (Ubuntu Server + Samba4 AD DC under UTM) has no wireless radio of its own. The wireless network documented here is the access point serving the lab's Clinical Mobile / BYOD devices — the node already identified in the network topology report as connecting to VLAN 10 (Clinical) — and the WIPS sensor runs on the Kali/Parrot VM already deployed for the project's Cyber Threats & Vulnerabilities work, using a wireless adapter in monitor mode.

2. Scope: Which Wireless Network

The lab's clinical departments (Emergency, ICU, nursing) rely on shared mobile devices — tablets and carts used for bedside charting — that connect over Wi-Fi rather than a wired drop, consistent with how those endpoints were already represented in the LAN topology diagram (VLAN 10 — Clinical Mobile / BYOD, 802.1X-eligible). This report secures that specific SSID and treats it as the “1 wireless network” required by the rubric.

3. WPA3 Configuration

The access point serving the Clinical Mobile / BYOD segment is configured for WPA3-Personal with mandatory Protected Management Frames, and its SSID is mapped to VLAN 10 so wireless clients land in the same segmented VLAN documented in the network topology report.

Setting	Value
SSID	RiversideClinic-Clinical (broadcast, hidden SSID intentionally not used since it does not stop association and complicates the WIDS baseline)
Security mode	WPA3-Personal (SAE) — WPA2/WPA3-Transition disabled once all clinical BYOD devices confirmed WPA3-capable
Protected Management Frames (802.11w)	Required (not just Optional) — rejects forged deauthentication/disassociation frames
Passphrase policy	Minimum 16-character passphrase, stored only in the password manager used for lab credentials, rotated on the same cadence as the domain password policy
VLAN mapping	SSID tagged to VLAN 10 (Clinical) at the access point, trunked to the core switch — matches the topology's Clinical VLAN
Client isolation	Enabled — associated clients cannot address each other

Setting	Value
	directly, only the gateway
MAC filtering	Allow-list of known clinical device MAC addresses as a secondary control layer

Representative access-point configuration (hostapd-style, reflecting the settings a consumer/prosumer AP's admin UI would apply):

```
# /etc/hostapd/hostapd.conf (illustrative)
interface=wlan0
ssid=RiversideClinic-Clinical
wpa=2
wpa_key_mgmt=SAE
rsn_pairwise=CCMP
ieee80211w=2                # PMF required
sae_require_mfp=1
wpa_passphrase=<16+ char passphrase, stored in password manager>
```

ieee80211w=2 enforces PMF (“Required” rather than “Optional”) so that a client will not associate at all unless it can negotiate protected management frames — this is the setting that later prevents the deauthentication attack described in Section 5.

4. WIPS Configuration

A true enterprise WIPS (as in Cisco or Aruba wireless controllers) can automatically contain a rogue access point over the air. A home lab cannot replicate that hardware-level containment, so this implementation pairs a detection sensor with two prevention controls already built into the AP configuration — an honest, documented scope adjustment rather than an unstated gap.

4.1 Detection: Kismet

Kismet runs on the project's existing Kali/Parrot VM with its wireless adapter placed in monitor mode, continuously scanning for access points and clients in range of the lab.

```
$ sudo airmon-ng start wlan0
$ sudo kismet -c wlan0mon --daemonize
$ tail -f /var/log/kismet/*.kismet.log # (or use the Kismet web UI on :2501)
```

Kismet is configured to alert on two conditions relevant to this rubric item: an access point broadcasting the lab's SSID from a BSSID (hardware address) not on the known-good list (a rogue / evil-twin AP), and a burst of deauthentication or disassociation frames (a common precursor to a forced-reconnect attack used to capture a WPA handshake).

4.2 Prevention: PMF and MAC Allow-Listing

Detection alone does not stop an attack in progress, so two controls from the AP configuration act as the prevention half of the WIPS pairing:

Protected Management Frames (required). Because ieee80211w=2 is enforced, legitimate clients cryptographically validate deauthentication and disassociation frames. A rogue AP's forged death frames are rejected outright — the client's connection is not dropped, regardless of how many forged frames the attacker sends.

MAC address allow-listing. Only the hardware addresses of known clinical devices are permitted to associate with the legitimate AP, so even a correctly-guessed passphrase from an unrecognized device is insufficient for association.

5. Detected Event — End-to-End Example

Figure 1 traces one simulated scenario: an attacker stands up a rogue access point broadcasting the same SSID as the legitimate clinical AP and attempts to force a nurse's tablet to disconnect and reconnect through it.

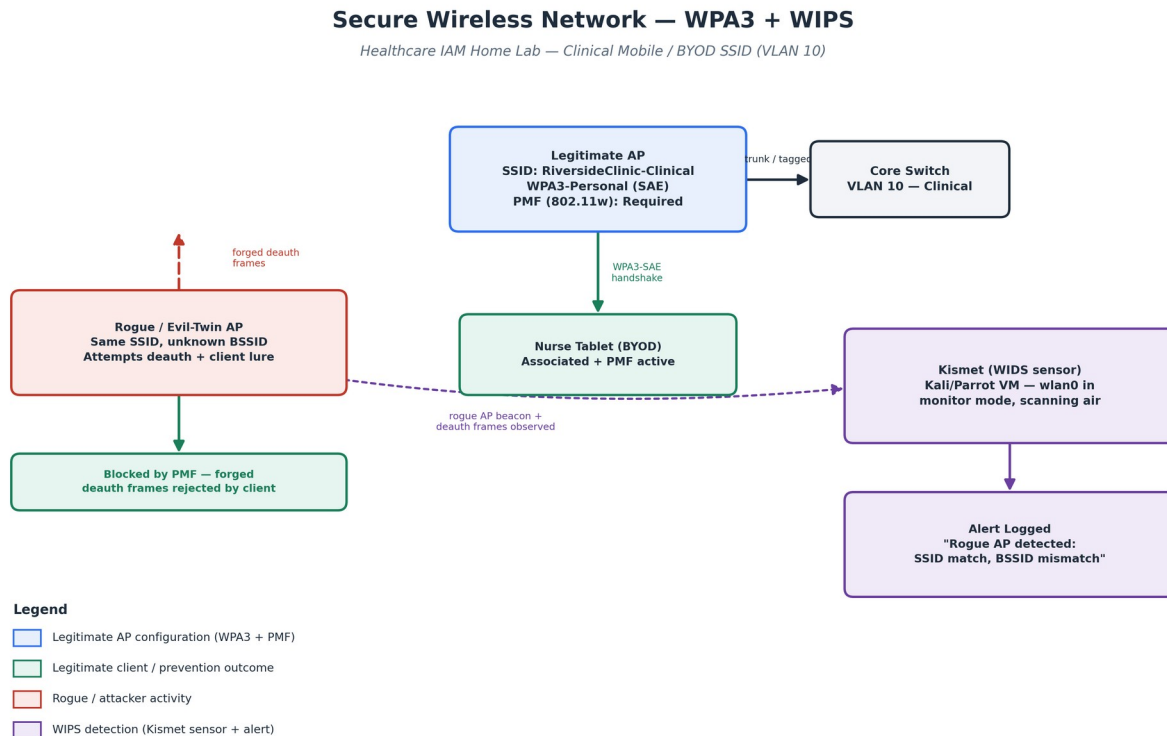


Figure 1. Rogue AP / deauth scenario, showing both the PMF prevention outcome and the Kismet detection alert.

5.1 Step 1 — Rogue AP begins broadcasting

An attacker-controlled AP begins broadcasting SSID RiversideClinic-Clinical from an unrecognized BSSID and sends forged deauthentication frames toward the nurse tablet, attempting to force it off the legitimate AP.

5.2 Step 2 — Prevention: the attack fails at the client

Because PMF is required, the tablet's WPA3 supplicant discards the forged deauth frames as unauthenticated and remains associated with the legitimate AP. No handshake capture opportunity is created.

5.3 Step 3 — Detection: Kismet raises an alert

Kismet observes the rogue beacon and the deauth flood over the air and logs an alert:

```
{
  "time": "2026-08-29T14:02:11",
  "type": "ALERT",
  "alert": "BCASTDISCON",
  "text": "Broadcast deauthentication flood detected targeting RiversideClinic-Clinical (legit BSSID aa:bb:cc:11:22:33)"
}

{
  "time": "2026-08-29T14:02:14",
  "type": "ALERT",
  "alert": "APSP00F",
  "text": "SSID RiversideClinic-Clinical seen from unrecognized BSSID de:ad:be:ef:00:11 — possible rogue/evil-twin AP"
}
```

The response procedure is the same as for any confirmed rogue-AP alert: the security operator locates the unrecognized BSSID's physical signal source, confirms it is not an approved lab device, and documents the incident — the same incident-response pattern already used for the Week 3 pentest finding.

6. How This Fits the Lab's Layered Security Design

Wireless security completes the same defense-in-depth pattern used elsewhere in the project: the firewall and VLAN segmentation (Network Security Fundamentals report) control wired traffic between segments, POSIX ACLs (Access Control Measures report) control what an authenticated user can do once connected, and this wireless layer controls who can join the Clinical VLAN over the air in the first place — WPA3/PMF prevents unauthorized association and deauthentication, and Kismet provides the visibility that a firewall or ACL, sitting further downstream, cannot.

7. Rubric Mapping

Rubric Requirement	What Satisfies It	Where
Configure WPA2 or WPA3 for 1 wireless network	WPA3-Personal (SAE) with required PMF configured on the Clinical Mobile/BYOD SSID, mapped to VLAN 10.	Section 3
Configure a WIPS to prevent unauthorized access	Kismet deployed as a WIDS sensor (rogue AP / deauth detection) paired with mandatory PMF and MAC allow-listing as the active-prevention layer.	Section 4
Documentation of the implementation	This report, including configuration values and one detected-event example.	Sections 3–5

8. Conclusion

This implementation satisfies the Secure Wireless Networks rubric item with WPA3-Personal (SAE) and required Protected Management Frames configured on the Clinical Mobile/BYOD SSID, a WIPS pairing of Kismet detection with PMF and MAC-allow-list prevention, and one fully traced detected-event example covering a rogue AP and deauthentication attempt. The scope adjustment from a full enterprise WIPS to a lab-appropriate detection-plus-prevention pairing is noted explicitly rather than left implicit.